

Análisis Técnico sobre Técnicas de Persistencia en Sistemas Windows

I. La Táctica de Persistencia: Fundamentos y Contexto Operacional en Windows

La persistencia es una táctica crítica para cualquier adversario o equipo de Red Team, permitiendo mantener un acceso continuo a un sistema comprometido a través de interrupciones como reinicios, cambios de credenciales o el cierre de la sesión inicial.¹ En el ecosistema Windows, esta fase se ve notablemente influenciada por la naturaleza centralizada del sistema operativo, a diferencia de la fragmentación de los entornos Linux. Los atacantes aprovechan el Registro de Windows, el sistema de servicios, y las funcionalidades de ejecución automática para establecer puntos de apoyo duraderos y resilientes.³

Para un atacante, la persistencia en Windows es fundamental porque:

- **Garantiza un punto de apoyo a largo plazo:** Permite al atacante reingresar al sistema en cualquier momento, incluso si la vulnerabilidad inicial es parcheada.⁴
- **Facilita la supervivencia:** Los mecanismos de persistencia están diseñados para sobrevivir a los reinicios del sistema y a los cierres de sesión de usuario.⁴
- **Permite el escalamiento:** Muchas técnicas de persistencia están intrínsecamente ligadas a la elevación de privilegios, permitiendo que el código malicioso se ejecute con permisos elevados como SYSTEM en cada inicio del sistema.⁷

El principal desafío para un atacante es el equilibrio entre la persistencia y la discreción. Un mecanismo de persistencia obvio, como un nuevo servicio con un nombre sospechoso, será detectado rápidamente. Por lo tanto, los adversarios avanzados prefieren técnicas que se camuflan dentro del comportamiento legítimo del sistema, abusando de funcionalidades de administración y depuración.⁸

II. Análisis de la Evidencia Fotográfica: El Catálogo de Metasploit

para la Persistencia en Windows

La imagen proporcionada ilustra una variedad de módulos de Metasploit diseñados para la persistencia en entornos Windows. Esta lista es una muestra clara de cómo la herramienta automatiza y simplifica técnicas que, de otra manera, requerirían una manipulación manual y compleja del sistema operativo.

- `exploit/windows/local/registry_persistence`: Este módulo es una interfaz directa para la técnica más común en Windows: la manipulación de las llaves del Registro de ejecución automática (Run Keys).⁵ Un atacante lo usaría para insertar una referencia a su payload en una de las llaves del Registro, asegurando que se ejecute cada vez que un usuario inicie sesión.⁵
- `exploit/windows/local/persistence_service`: Al igual que su contraparte en Linux, este módulo está diseñado para crear o modificar un servicio de Windows para que ejecute el payload del atacante. Es una técnica poderosa porque los servicios pueden ser configurados para iniciarse automáticamente durante el arranque del sistema y, en muchos casos, se ejecutan con privilegios de SYSTEM, el nivel más alto de permisos en el sistema.⁷
- `post/windows/manage/sticky_keys`: Este módulo es un ejemplo clásico de cómo un atacante abusa de una funcionalidad legítima para sus fines maliciosos. Explota una característica de accesibilidad de Windows (las Sticky Keys) para ejecutar una shell de comandos (`cmd.exe`) con privilegios de SYSTEM desde la pantalla de inicio de sesión, simplemente presionando la tecla Shift cinco veces seguidas.⁸
- `exploit/windows/local/persistence_exe`: Este módulo representa un enfoque más genérico. Es una forma sencilla de crear un payload persistente, ya sea para un servicio de sistema o para una ejecución a nivel de usuario. La documentación de Metasploit menciona que este módulo (`persistence.rb`) permite crear un servicio Meterpreter que estará disponible incluso después de que el sistema se reinicie, pero advierte que deja una puerta trasera no autenticada.¹⁰
- `exploit/windows/local/persistence_image_exec_options`: Este módulo se relaciona con una técnica avanzada de evasión: la manipulación del Registro Image File Execution Options (IFEEO). Los atacantes abusan de la llave Debugger para redirigir la ejecución de una aplicación legítima a su payload malicioso, proporcionando un método de persistencia sigiloso.¹¹

El catálogo de Metasploit demuestra que la persistencia en Windows se ha vuelto altamente automatizada, permitiendo a los atacantes con menos experiencia abusar de mecanismos complejos del sistema con un simple `run`. Para el Blue Team, esto significa que la detección debe centrarse en el comportamiento anómalo más que en la simple búsqueda de malware estático.

III. Persistencia en el Ecosistema MITRE ATT&CK: Un Análisis Táctico

La táctica **MITRE ATT&CK TA0003 - Persistencia** ⁴ clasifica un vasto número de técnicas, y las siguientes son algunas de las más relevantes para sistemas Windows.

T1547.001 - Registry Run Keys / Startup Folder

- **Funcionamiento:** Esta es la técnica de persistencia más común y confiable en Windows. Los atacantes añaden una entrada en las llaves del Registro como HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Run (a nivel de usuario) o HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Run (a nivel de sistema) que apunta a un programa o script malicioso.⁵ Cuando el sistema o el usuario inician sesión, el programa se ejecuta automáticamente.⁵
- **Ventajas:** Es extremadamente confiable y se ejecuta como parte del comportamiento esperado del sistema operativo, lo que la hace difícil de detectar sin un monitoreo específico.⁵
- **Detección y Mitigación:** Los defensores deben monitorear continuamente las llaves del Registro de ejecución automática. Herramientas como Sysmon pueden configurarse para generar eventos (Event ID 12, 13, 14) cuando se modifican estas llaves.⁵ La mitigación incluye la restricción de privilegios de usuario y la auditoría de cambios en estas ubicaciones.

T1543.003 - Windows Service

- **Funcionamiento:** Un adversario con privilegios administrativos puede crear un nuevo servicio de Windows o modificar uno existente para ejecutar un payload malicioso.⁷ Los servicios se ejecutan en segundo plano y pueden configurarse para iniciarse en el arranque del sistema, a menudo con los máximos privilegios (SYSTEM).⁷
- **Ventajas:** Proporciona un punto de apoyo extremadamente potente y de alto privilegio que sobrevive a los reinicios y a las sesiones de usuario.⁷
- **Detección y Mitigación:** La creación o modificación de un servicio es una acción con muchos indicadores. La detección puede lograrse monitoreando las llaves del Registro

relacionadas con los servicios y los logs de creación de procesos (Sysmon Event ID 1). La mitigación se centra en el principio de mínimo privilegio y en un hardening estricto del sistema.

T1098.007 - Additional Local or Domain Groups

- **Funcionamiento:** Esta técnica no se basa en la ejecución de código, sino en el abuso de la infraestructura de administración de identidades. Un atacante añade su cuenta maliciosa (o una cuenta legítima comprometida) a un grupo con privilegios elevados, como "Administrators" o "Domain Admins".¹³
- **Ventajas:** Utiliza credenciales válidas y rutas de acceso legítimas, lo que permite al atacante eludir los mecanismos de detección basados en malware.³
- **Detección y Mitigación:** La detección requiere una auditoría rigurosa de los grupos de seguridad y los cambios de membresía. Los defensores deben monitorear los logs de eventos de seguridad que registran estas modificaciones. La mitigación pasa por una revisión periódica de cuentas y grupos, y la implementación de políticas de "least privilege".

A continuación, se presenta una tabla que resume estas técnicas clave para una referencia rápida:

ID ATT&CK	Nombre de la Técnica	Descripción del Mecanismo	Ventajas para el Atacante	Estrategias de Detección	Recomendaciones de Mitigación
T1547.001	Registry Run Keys / Startup Folder	Añade una entrada en las llaves del Registro o en la carpeta Startup para ejecutar un programa en cada inicio de sesión.	Confiable, simple, utiliza un mecanismo legítimo del SO.	Monitoreo del Registro con Sysmon (Event ID 12, 13, 14). Detección de binarios inesperados en la carpeta Startup.	Restricción de permisos de usuario, uso de Application Whitelisting .

T1543.003	Windows Service	Crea o modifica un servicio para ejecutar un payload con altos privilegios (SYSTEM) en el arranque del sistema.	Proporciona el máximo nivel de persistencia y privilegios. Es difícil de detectar sin monitoreo en profundidad.	Monitoreo de creación de procesos con Sysmon (Event ID 1). Búsqueda de servicios sospechosos.	Aplicación de principio de mínimo privilegio. Hardening del sistema.
T1098.007	Additional Local or Domain Groups	Añade una cuenta a un grupo de seguridad privilegiado (Administrators, Domain Admins) para mantener el acceso.	Utiliza credenciales válidas, camuflándose como una actividad legítima.	Auditoría de logs de eventos de seguridad (Security Event Logs) para cambios en la membresía de grupos.	Revisión periódica de cuentas, hardening de políticas de cuentas.
T1546.008	Image File Execution Options Injection	Abusa de la llave Debugger del Registro para redirigir la ejecución de una aplicación legítima a un payload malicioso.	Abusa de una funcionalidad legítima de depuración, lo que lo hace muy sigiloso.	Monitoreo de cambios en la llave IFEO del Registro con Sysmon (Event ID 12, 13, 14).	Control de acceso estricto a las llaves críticas del Registro.

IV. Metasploit y Meterpreter: Facilitando el Punto de Apoyo

El framework de Metasploit, con su arquitectura modular, ha simplificado en gran medida el proceso de establecer persistencia en Windows.¹⁰ Los módulos de post-explotación, como el `persistence.rb` (run `persistence_exe`), están diseñados para automatizar la creación de una puerta trasera robusta sin que el atacante tenga que escribir código complejo o manipular el Registro manualmente.¹⁰

Un flujo de trabajo típico para un atacante sería el siguiente:

1. **Explotación Inicial:** Usar un exploit para obtener una sesión de Meterpreter en el sistema objetivo.¹⁰
2. **Escalada de Privilegios:** Utilizar un módulo de elevación de privilegios para obtener acceso de SYSTEM o Administrator.
3. **Establecer Persistencia:** Desde la sesión de Meterpreter, el atacante puede usar un comando como `run persistence -U` (para iniciar en el inicio de sesión del usuario) o `run persistence -S` (para crear un servicio que se inicia en el arranque) para dejar un payload que se conecta de nuevo a su handler en intervalos definidos.¹⁰

Metasploit se encarga de todo el trabajo sucio, desde la creación del payload hasta su ubicación en un directorio temporal y la manipulación de la llave del Registro o el servicio de Windows correspondiente.¹⁰

V. Persistencia Avanzada: Abusando del Núcleo de Windows

Los atacantes avanzados van más allá de los métodos comunes, explotando funcionalidades menos obvias para evadir la detección y mantener un acceso sigiloso y de alto privilegio.

- **Suscripciones a Eventos WMI:** Windows Management Instrumentation (WMI) es un marco de administración poderoso. Los adversarios pueden abusar de WMI creando "suscripciones de eventos permanentes" que residen en el repositorio WMI en lugar del Registro.⁸ Estas suscripciones pueden configurarse para ejecutar un payload en respuesta a un evento del sistema (por ejemplo, el inicio de un proceso específico, un intervalo de tiempo o un evento de logging), lo que proporciona una persistencia extremadamente discreta que no es visible con las herramientas de inspección del Registro habituales.⁸
- **Manipulación del Registro `AppInit_DLLs` y `AppCertDlls`:** Estas llaves del Registro están diseñadas para cargar bibliotecas (DLLs) en la memoria de los procesos del

sistema. Un atacante con permisos de SYSTEM puede modificar estas llaves para inyectar su DLL maliciosa en casi todos los procesos que se ejecutan en el sistema (AppInit_DLLs), o en aquellos que llaman a funciones de creación de procesos (AppCertDlls).¹¹ Esta técnica permite un acceso sigiloso a un nivel de ejecución profundo.

VI. Detección y Contramedidas: El Muro del Blue Team

Estrategias de Detección Proactiva

- **Análisis de Logs de Eventos de Windows:** Los logs de eventos de seguridad son la fuente de datos más valiosa para un Blue Team.
 - **Sysmon:** Es una herramienta fundamental. Un Blue Team debe configurar Sysmon para monitorear eventos críticos como la creación de procesos (Event ID 1), los cambios en el Registro (Event ID 12, 13, 14) y la creación de archivos. La correlación de la creación de un servicio inusual con una modificación del Registro puede ser una clara señal de un intento de persistencia.¹¹
 - **Monitoreo del Registro:** El monitoreo continuo de las llaves Run, RunOnce, ServiceDLL y IFEO es crucial para detectar la mayoría de las técnicas de persistencia.
- **Caza de Amenazas (Threat Hunting):** Más allá del monitoreo pasivo, los equipos deben buscar activamente indicadores de compromiso. La búsqueda de archivos binarios inesperados en directorios temporales o de sistema (C:\Windows\TEMP) o la ejecución de procesos de cmd.exe sin un proceso padre lógico son ejemplos de actividades sospechosas que deben ser investigadas.

Recomendaciones de Hardening

- **Principio de Mínimo Privilegio:** Limitar los privilegios de los usuarios y servicios para reducir la superficie de ataque. La mayoría de las técnicas de persistencia a nivel de sistema requieren privilegios administrativos para ser implementadas.¹⁵
- **Gestión de Parches:** Asegurar que los sistemas estén actualizados es una defensa fundamental. Sin embargo, un atacante avanzado puede parchear una vulnerabilidad una vez que ha logrado su persistencia para evitar ser detectado por otros atacantes o escáneres de vulnerabilidad.¹⁶ Esto enfatiza la importancia de una auditoría proactiva.

- **Application Whitelisting:** Implementar políticas de whitelisting para permitir que solo las aplicaciones conocidas y confiables se ejecuten en el sistema, lo que puede frustrar muchos intentos de persistencia basados en la ejecución de payloads no autorizados.⁴

VII. Conclusiones y Retrospectiva del Red Team

La persistencia en Windows es un juego táctico que se centra en el conocimiento profundo de las entrañas del sistema operativo. A diferencia de la diversidad de Linux, el entorno de Windows ofrece un conjunto de puntos de entrada de persistencia que, si bien son conocidos, continúan siendo altamente efectivos. Metasploit ha democratizado estas técnicas, pero la batalla real se libra en la capacidad del Blue Team para detectar comportamientos anómalos. La verdadera defensa se basa en un monitoreo holístico, que combine el análisis de logs, la caza de amenazas proactiva y un hardening riguroso. Al entender cómo los atacantes abusan de las funcionalidades de Windows, los defensores pueden construir un muro más robusto y resistente.

Obras citadas

1. Amenazas persistentes avanzadas: qué son y cómo protegerse | S2GRUPO, fecha de acceso: septiembre 7, 2025, <https://s2grupo.es/amenazas-persistentes-avanzadas-que-son-y-como-protegerse/>
2. Deep Dive on Persistence, Privilege Escalation Technique and Detection in Linux Platform, fecha de acceso: septiembre 7, 2025, https://www.splunk.com/en_us/blog/security/deep-dive-on-persistence-privilege-escalation-technique-and-detection-in-linux-platform.html
3. Overview of MITRE ATT&CK Tactic 3: Persistence (TA0003) - DevCentral, fecha de acceso: septiembre 7, 2025, <https://community.f5.com/kb/technicalarticles/overview-of-mitre-attck-tactic-3-persistence-ta0003/342694>
4. What is MITRE ATT&CK Persistence (TA0003)? - Netscout, fecha de acceso: septiembre 7, 2025, <https://www.netscout.com/what-is-mitre-attack/persistence>
5. How to Discover Windows Run Key Persistence When Threat Hunting - Insane Cyber, fecha de acceso: septiembre 7, 2025, <https://insanecyber.com/run-key-persistence-threat-hunting-guide/>
6. Boot or Logon Autostart Execution: Registry Run Keys / Startup Folder - MITRE ATT&CK®, fecha de acceso: septiembre 7, 2025, <https://attack.mitre.org/techniques/T1547/001/>
7. ATT&CK Technique T1543.003 - Mappings Explorer - GitHub Pages, fecha de acceso: septiembre 7, 2025, <https://center-for-threat-informed-defense.github.io/mappings-explorer/attack/a>

- [ttack-12.1/domain-enterprise/techniques/T1543.003/](#)
8. Advanced Windows Persistence, Part 1: Remaining Inside the Windows Target, fecha de acceso: septiembre 7, 2025, <https://hackers-arise.com/advanced-windows-persistence-part-1-remaining-inside-the-windows-target/>
 9. T1543.003 Windows Service - Матрица MITRE ATT&CK - Positive Technologies, fecha de acceso: septiembre 7, 2025, <https://mitre.ptsecurity.com/en-US/T1543.003>
 10. Meterpreter Service - Metasploit Unleashed - OffSec, fecha de acceso: septiembre 7, 2025, <https://www.offsec.com/metasploit-unleashed/meterpreter-service/>
 11. Ten process injection techniques: A technical survey of common and trending process injection techniques - Elastic, fecha de acceso: septiembre 7, 2025, <https://www.elastic.co/blog/ten-process-injection-techniques-technical-survey-common-and-trending-process>
 12. Windows Persistence - - HADESS, fecha de acceso: septiembre 7, 2025, <https://hadess.io/wp-content/uploads/2023/11/Windows-Persistence.pdf>
 13. Persistence, Tactic TA0003 - Enterprise | MITRE ATT&CK®, fecha de acceso: septiembre 7, 2025, <https://attack.mitre.org/tactics/TA0003/>
 14. Persistence - MITRE ATT&CK Techniques - Red Canary, fecha de acceso: septiembre 7, 2025, <https://redcanary.com/resources/webinars/attck-deep-dive-persistence/>
 15. CCN-CERT BP/01 Principios y recomendaciones básicas en Ciberseguridad, fecha de acceso: septiembre 7, 2025, https://www.ucm.es/data/cont/media/www/pag-114974/CCN-CERT_BP_01.pdf
 16. Patching for persistence: How DripDropper Linux malware moves through the cloud, fecha de acceso: septiembre 7, 2025, <https://redcanary.com/blog/threat-intelligence/dripdropper-linux-malware/>